비밀번호 보안 설명서 / Tài liệu giải thích bảo mật mật khẩu

TMeet · Supabase Auth · bcrypt · JWT · RLS · 한국어 + Tiếng Việt · v2.0 (2026-11-10)

1. 한눈에 보기 / Tóm tắt

KR TMeet 이 만든 테이블(profiles 등)에는 비밀번호가 전혀 없습니다. 로그인은 Supabase Auth 가 맡고, Supabase Auth 는 비밀번호를 bcrypt 로 해시해서 auth.users.encrypted_password 컬럼에 해시만 저장합니다. 원래 비밀번호는 어디에도 남지 않습니다 (NFR-12).

VI Các bảng do TMeet tạo (profiles…) hoàn toàn không chứa mật khẩu. Đăng nhập do Supabase Auth đảm nhận; Supabase Auth băm mật khẩu bằng bcrypt và chỉ lưu bản băm vào cột auth.users.encrypted_password. Mật khẩu gốc không được lưu ở đâu cả (NFR-12).

KR 컬럼 이름에 "encrypted(암호화)"가 들어 있지만 실제로는 암호화가 아니라 해시입니다. Supabase 공식 문서도 이름이 잘못 붙은 것이라고 설명합니다.

VI Tên cột có chữ "encrypted (mã hóa)" nhưng thực chất là băm, không phải mã hóa. Tài liệu chính thức của Supabase cũng nói đây là tên đặt chưa đúng, giữ lại vì tương thích.

2. 해시와 암호화의 차이 / Băm khác mã hóa như thế nào

	해시 / Băm (hash)	암호화 / Mã hóa (encrypt)
방향 / Chiều	단방향 / Một chiều	양방향 / Hai chiều
되돌리기 / Đảo ngược	불가능 / Không thể	키가 있으면 가능 / Được, nếu có khóa
용도 / Dùng cho	비밀번호 확인 / Kiểm tra mật khẩu	나중에 다시 읽어야 하는 데이터 / Dữ liệu cần đọc lại
TMeet 예 / Ví dụ	auth.users.encrypted_password (bcrypt)	HTTPS(TLS): 앱 ↔ Supabase 통신 전체 / Toàn bộ kết nối app ↔ Supabase

KR 비밀번호는 다시 읽을 필요가 없으므로 해시합니다. 앱에서 서버로 가는 길은 HTTPS 로 암호화되어, 중간에서 비밀번호를 엿볼 수 없습니다.

VI Mật khẩu không cần đọc lại nên được băm. Đường truyền từ app lên server được mã hóa bằng HTTPS nên không ai nghe lén được mật khẩu ở giữa.

3. 가입과 로그인 흐름 / Luồng đăng ký và đăng nhập

```
[가입 / Đăng ký]
앱 signUp(email, 비밀번호) ──HTTPS──▶ Supabase Auth
   └ bcrypt 해시 → auth.users.encrypted_password 저장, 원문은 버림
   └ 트리거 → profiles 한 줄 생성 (비밀번호 없음)
   └ 인증 메일 발송 → 링크 클릭 → email_confirmed_at 기록

[로그인 / Đăng nhập]
앱 signInWithPassword ──HTTPS──▶ Supabase Auth
   └ 저장된 해시 속 salt 로 입력값을 다시 해시해 비교
   └ 같으면 access token(JWT, 약 1시간) + refresh token 발급 → 앱 AsyncStorage 에 보관
   └ 다르면 거부 (Invalid login credentials)

[이후 모든 요청 / Mọi yêu câù sau đó]
앱 ──JWT──▶ Supabase — RLS: auth.uid() = 로그인한 사람 id ─▶ PostgreSQL
```

KR 가입: 앱이 이메일과 비밀번호를 HTTPS 로 Supabase Auth 에 보냅니다. Auth 는 bcrypt 로 해시해 저장하고 원문은 버립니다. 이메일 인증 링크를 누르기 전에는 로그인할 수 없습니다(FR-39). 로그인: 입력한 비밀번호를 저장된 해시 안의 salt 로 다시 해시해 비교하고, 같으면 JWT 토큰을 줍니다. 앱은 이후 모든 요청에 이 토큰을 붙이고, DB 의 RLS 규칙은 토큰 속 사용자 id(auth.uid())로 "본인 데이터인가" 를 검사합니다.

VI Đăng ký: app gửi email và mật khẩu qua HTTPS tới Supabase Auth. Auth băm bằng bcrypt, lưu bản băm và bỏ bản gốc. Chưa bấm link xác thực email thì chưa đăng nhập được (FR-39). Đăng nhập: mật khẩu vừa nhập được băm lại bằng salt nằm trong bản băm đã lưu rồi so sánh; giống thì cấp token JWT. Từ đó app gắn token vào mọi yêu cầu, và quy tắc RLS trong CSDL dùng id người dùng trong token (auth.uid()) để kiểm tra "có phải dữ liệu của chính mình không".

4. bcrypt 해시 문자열 읽는 법 / Cách đọc chuỗi băm bcrypt

Tmeet2026! 를 bcrypt(cost 10)로 해시한 실제 예시입니다 (우리 Supabase DB 의 pgcrypto 로 생성). / Ví dụ thật khi băm Tmeet2026! bằng bcrypt (cost 10), tạo bằng pgcrypto trong CSDL Supabase của nhóm:

```
$2a$10$rZpztV.aGBKnAgjGUWSyFOzMBu5wqCPexDYOUXZWT6WLl5DDXYfdW
```

부분 / Phần	값 / Giá trị	의미 / Ý nghĩa
$2a$	알고리즘 버전 / Phiên bản	bcrypt 버전 표시 / Đánh dấu phiên bản bcrypt
10$	cost = 10	2^10 = 1024 번 반복. 높을수록 느리고 안전 / Lặp 1024 vòng, càng cao càng chậm và an toàn
rZpztV.aGBKnAgjGUWSyFO	salt (22 자 / ký tự)	무작위 값, 해시 안에 함께 저장 / Giá trị ngẫu nhiên, lưu ngay trong chuỗi
zMBu5wqCPexDYOUXZWT6WLl5DDXYfdW	해시 결과 (31 자 / ký tự)	비밀번호 + salt 로 계산한 결과 / Kết quả tính từ mật khẩu + salt

전체 길이는 항상 60 자입니다. / Tổng độ dài luôn là 60 ký tự.

Salt 란? / Salt là gì?

KR salt 는 해시할 때마다 새로 만드는 무작위 값입니다. 같은 비밀번호를 두 번 해시해도 결과가 다르므로, 두 사람이 같은 비밀번호를 써도 DB 에서는 구분되지 않고, 미리 계산해 둔 해시 표(레인보우 테이블)로 되돌릴 수 없습니다.

VI Salt là giá trị ngẫu nhiên tạo mới mỗi lần băm. Cùng một mật khẩu băm hai lần cho hai kết quả khác nhau, nên hai người dùng chung mật khẩu cũng không lộ ra trong CSDL, và không thể tra ngược bằng bảng băm tính sẵn (rainbow table).

```
1 회 / lần 1:  $2a$10$rZpztV.aGBKnAgjGUWSyFOzMBu5wqCPexDYOUXZWT6WLl5DDXYfdW
2 회 / lần 2:  $2a$10$14XUMKVKCZUFl20ibo5ZU.OD7NDtEs9ZHjlVJkHOJfUW7MEdXssvW
```

5. TMeet 의 비밀번호·계정 규칙 / Quy tắc mật khẩu và tài khoản của TMeet

규칙 / Quy tắc	어디서 지키나 / Thực hiện ở đâu
비밀번호 8 자 이상, 확인 칸 일치 / ≥8 ký tự, ô xác nhận khớp	앱 가입 화면(S03, A) + src/api/auth.js signUp + Supabase Auth 최소 길이 설정 (8) / App + Supabase Auth
이메일 인증 필수 / Bắt buộc xác thực email	Supabase Auth "Confirm email" 켬, 인증 전 로그인 불가 (FR-39)

규칙 / Quy tắc	어디서 지키나 / Thực hiện ở đâu
만 18 세·약관 동의 / ≥18 tuổi, đồng ý điều khoản	가입 시 체크 → 트리거가 profiles.terms_agreed_at 기록 (FR-40)
비밀번호를 우리 테이블에 두지 않음 / Không lưu mật khẩu ở bảng của nhóm	profiles 에 비밀번호 컬럼 없음, auth.users 는 Supabase 만 접근 (NFR-12)
로그인 유지 / Giữ đăng nhập	refresh token 을 AsyncStorage 에 보관, 앱이 앞에 있을 때 자동 갱신 (FR-02)
비밀 키 분리 / Tách khóa bí mật	앱에는 공개 키(anon/publishable)만. service_role 키·AI 키는 Edge Function Secrets 에만 (NFR-05, NFR-18)
로그인 안 한 요청 / Yêu cầu chưa đăng nhập	모든 테이블·함수 접근 거부 (RLS + 권한)
탈퇴 / Xóa tài khoản	delete-account 함수가 auth.users 삭제 → 해시도 함께 삭제 (FR-42)

6. 이전 설계에서 바뀐 점 / Thay đổi so với thiết kế cũ

이전 / Trước	지금 / Bây giờ
Node.js 백엔드가 bcrypt.hash 로 직접 해시, MySQL User.passwordHash 에 저장	Supabase Auth 가 bcrypt 로 해시, auth.users.encrypted_password 에 저장. 우리 코드는 비밀번호를 다루지 않음
백엔드가 JWT 직접 발급·검증	Supabase Auth 가 JWT 발급, DB 의 RLS 가 검증
이메일 인증 없음	이메일 인증 필수 (FR-39)
상세 일정 AES-256-GCM 암호화 (ScheduleConsent)	기능 삭제 (여행 계획 카드는 3 순위)